



# Modbus TCP em CLP Real

E o Modelo Purdue

Gabriel de Oliveira e Silva

Monitoria de Introdução às Redes de Comunicação, UFPE

2026.2

MODBUS

# Roteiro da aula

## Prática com hardware

- Recuperando o cliente.js
- Identificando a biblioteca do CLP
- Configurando o servidor Modbus TCP
- Testando com hardware real

## Análise e teoria

- Wireshark em detalhe
- Modelo Purdue
- Mapeando a bancada

## Bloco 1: recuperando o cliente.js

- Mesmo arquivo da Aula 1, nenhuma linha muda hoje
- Classe `ClienteModbusTCP`: `conectar`, `lerRegistradores`, `escreverRegistradores`, `encerrar`
- Se a pasta da Aula 1 não estiver disponível, recriar a partir do notebook de hoje

## Bloco 2: identificando a biblioteca do CLP

### Nomes dos parâmetros no bloco

### Biblioteca

dataBuffer, connectParamServer,  
ndr, dataRead (minúsculas)

Legada, siga o Caminho A

MB\_HOLD\_REG, CONNECT, NDR, DR,  
DISCONNECT (maiúsculas)

Atual v4.0+, siga o Caminho B

- Em caso de dúvida: painel de informação do bloco, ícone 

## Bloco 3: preparação comum

- IP do CLP: *Device configuration* → porta PROFINET → *Properties* > *General* > *Ethernet addresses*
- Criar DB\_HoldingRegisters com holdingRegister : Array[0..99] of Word
- Confirmar *Optimized block access* marcado

## Bloco 3, Caminho A: biblioteca legada

| Parâmetro                       | Valor / explicação                                   |
|---------------------------------|------------------------------------------------------|
| <code>disconnect</code>         | <code>FALSE</code> , mantém a conexão passiva aberta |
| <code>connectParamServer</code> | estrutura <code>TCON_IP_v4</code>                    |
| <code>dataBuffer</code>         | <code>DB_HoldingRegisters.holdingRegister</code>     |

Saídas: `ndr` (escrita), `dataRead` (leitura), `error`, `status`. Function codes aceitos: 3, 6, 16.

## Bloco 3, Caminho B: biblioteca atual (v4.0+)

| Parâmetro | Valor / explicação |
|-----------|--------------------|
|-----------|--------------------|

|            |       |
|------------|-------|
| DISCONNECT | FALSE |
|------------|-------|

|         |                                       |
|---------|---------------------------------------|
| CONNECT | estrutura TCON_IP_v4, parâmetro InOut |
|---------|---------------------------------------|

|             |                                            |
|-------------|--------------------------------------------|
| MB_HOLD_REG | DB_HoldingRegisters.holdingRegister, InOut |
|-------------|--------------------------------------------|

Saídas: NDR, DR, ERROR, STATUS. Function codes aceitos: 1, 2, 3, 4, 5, 6, 8, 11, 15, 16, 23.

## Bloco 3: estrutura TCON\_IP\_v4 (1/2)

| Campo          | Valor                               |
|----------------|-------------------------------------|
| InterfaceId    | HW Identifier da interface PROFINET |
| ID             | 1 a 4095, único nesse CLP           |
| ConnectionType | 11 decimal, fixo para TCP           |

## Bloco 3: estrutura TCON\_IP\_v4 (2/2)

| Campo             | Valor                              |
|-------------------|------------------------------------|
| ActiveEstablished | FALSE, o servidor espera a conexão |
| RemotePort        | 0, aceita qualquer cliente         |
| LocalPort         | 502, porta padrão Modbus TCP       |

## Bloco 3: compilar e colocar em RUN

- *Download to device > Hardware and Software (only changes)*
- Colocar a CPU em RUN
- LED RUN verde fixo, sem ERROR nem MAINT piscando
- Se houver erro: checar status ou STATUS numa Watch Table

## Bloco 4: Watch Table antes de rodar

- *Watch and force tables > Add new watch table*
- Adicionar `DB_HoldingRegisters.holdingRegister[0..3]`
- Clicar no ícone de óculos, *Monitor all*

## Bloco 4: rodando o cliente contra o CLP

### Saída esperada no terminal

Conectado ao CLP

Registradores antes: [ 100, 200, 300, 400 ]

Escrita concluída

Registradores depois: [ 11, 22, 33, 44 ]

Ao mesmo tempo, a Watch Table do TIA Portal mostra os mesmos quatro valores mudando.

## Bloco 4: solução de problemas

| Sintoma                            | Causa provável                                                 |
|------------------------------------|----------------------------------------------------------------|
| ECONNREFUSED                       | CLP fora do RUN, ou porta configurada diferente de 502         |
| Conexão trava sem erro nem sucesso | notebook e CLP fora da mesma sub-rede, ou cabo na porta errada |
| ndr/NDR nunca vira 1               | buffer não aponta pro DB certo, ou acesso não otimizado        |
| LED ERROR aceso                    | checar status/STATUS na Watch Table                            |

## Bloco 5: sequência esperada no Wireshark

| Grupo                  | Pacotes | Conteúdo          |
|------------------------|---------|-------------------|
| Handshake TCP          | 1 a 3   | SYN, SYN-ACK, ACK |
| Leitura (FC 3)         | 4 e 5   | Query e Response  |
| Escrita (FC 16)        | 6 e 7   | Query e Response  |
| Leitura de novo (FC 3) | 8 e 9   | Query e Response  |

## Bloco 5: examinando o handshake

- Ethernet II: Destination e Source (MAC)
- Internet Protocol Version 4: Source Address, Destination Address, Protocol 6
- TCP: Source Port, Destination Port
- TCP Flags: SYN no pacote 1, SYN+ACK no 2, ACK no 3
- Sequence Number e Acknowledgment Number sincronizam os dois lados

## Bloco 5: o cabeçalho MBAP

| Campo                  | Valor observado              |
|------------------------|------------------------------|
| Transaction Identifier | caso o pedido com a resposta |
| Protocol Identifier    | 0, identifica Modbus         |
| Unit Identifier        | 1                            |

## Bloco 5: a PDU de leitura (Function Code 3)

| Campo                                 | Valor observado           |
|---------------------------------------|---------------------------|
| Function Code                         | 3, Read Holding Registers |
| Reference Number / Word Count         | 0 / 4                     |
| Resposta: Byte Count e Register 0 a 3 | 8 bytes, valores lidos    |

## Bloco 5: PDU de escrita (Function Code 16)

- Function Code muda para 16
- PDU do pedido carrega mais campos: Starting Address, Quantity of Registers, Byte Count
- Os valores escritos aparecem um a um, em campos Register N: 11, 22, 33, 44
- A resposta confirma só Starting Address e Quantity, sem repetir os valores

## Bloco 5: o que essa análise mostra

### **Sem cifra, sem autenticação**

Nenhum campo do MBAP ou da PDU está cifrado. Não existe usuário, senha ou token em nenhuma parte do pacote. Qualquer dispositivo que alcance a porta 502 do CLP pode montar um pacote igual ao pacote 6 e obter o mesmo efeito.

## Bloco 6: o que é o modelo Purdue

- Purdue Enterprise Reference Architecture
- Organiza a rede industrial em níveis hierárquicos, do processo físico à rede corporativa
- Criado nos anos 90 para manufatura integrada por computador
- Hoje é referência em segurança OT: mostra onde a TI termina e o controle industrial começa

## Bloco 6: os níveis do modelo Purdue (1/2)

| Nível | O que fica ali  | Já visto no período           |
|-------|-----------------|-------------------------------|
| 0     | processo físico | o processo do CLP de hoje     |
| 1     | CLP, RTU        | o S7-1200 como MB_SERVER      |
| 2     | IHM, SCADA      | o SCADA do material de Modbus |

## Bloco 6: os níveis do modelo Purdue (2/2)

| Nível | O que fica ali        | Já visto no período        |
|-------|-----------------------|----------------------------|
| 3     | MES, historian        | ainda não visto na prática |
| 3.5   | DMZ industrial        | não existe hoje na bancada |
| 4     | TI da planta          | ainda não visto na prática |
| 5     | ERP, e-mail, internet | a internet do Bloco 0      |

## Bloco 6: por que isso importa para segurança

### A barreira do Nível 3.5

O tráfego não deveria passar direto do Nível 5 para o Nível 0 ou 1. A DMZ industrial existe para quebrar esse caminho direto. Nada de TI se comunica diretamente com OT, tudo passa por uma zona intermediária com regras explícitas.

## Bloco 6: o caso Stuxnet

### Stuxnet, 2010

*CLPs Siemens controlando centrífugas em uma instalação isolada da internet. O malware chegou por pendrives infectados, cruzando exatamente a fronteira entre níveis que o modelo Purdue existe para proteger, e mostrava aos operadores leituras normais enquanto alterava a lógica do controlador.*

## Bloco 6: o que fica na DMZ industrial

| Componente                      | Função                                                       |
|---------------------------------|--------------------------------------------------------------|
| Réplica do historian            | espelha dados do Nível 3 sem acesso direto ao historian real |
| Servidor de patches e antivírus | distribui atualizações sem OT sair para a internet           |
| Jump host                       | ponto único e monitorado de acesso remoto à rede OT          |

Regra prática: nenhum equipamento do Nível 4 ou 5 fala direto com o Nível 0, 1, 2 ou 3.

## Bloco 6: zonas e condutos (IEC 62443)

### **Zona**

Agrupamento de ativos que compartilham o mesmo nível de exigência de segurança.

### **Conduto**

Caminho de comunicação entre zonas, controlado e monitorado, não aberto.

## Bloco 6: Security Levels (IEC 62443)

### SL Resiste a

- 0 nenhuma exigência específica
- 1 violação casual ou acidental
- 2 violação intencional, meios simples
- 3 violação intencional, meios sofisticados
- 4 ataque com recursos extensos, como um estado

## Bloco 6: exemplo fora da bancada

| Zona                 | Nível | Equipamentos                      |
|----------------------|-------|-----------------------------------|
| Processo             | 0 e 1 | bombas, válvulas, CLPs de dosagem |
| Supervisão           | 2     | IHM, SCADA local                  |
| Operações do site    | 3     | historian, relatórios             |
| DMZ industrial       | 3.5   | réplica do historian, jump host   |
| TI da concessionária | 4 e 5 | e-mail, ERP, internet             |

## Bloco 6: a bancada de hoje

- O CLP de hoje corresponde ao Nível 1
- O notebook com o cliente.js deveria operar perto do Nível 1 ou 2, não como um notebook qualquer
- O switch é o meio físico entre os dois

### Pergunta central

Existe hoje alguma zona ou conduto real entre o notebook e o CLP?

## Bloco 6: limitações do modelo

- Redes reais raramente são tão organizadas quanto o diagrama sugere
- Acesso remoto de manutenção, envio de dados para nuvem e integrações de emergência costumam pular níveis inteiros
- Parte do trabalho de segurança OT é comparar a rede desenhada com a rede que existe de fato

## Bloco 7: mapeando a bancada

- Listar os equipamentos da montagem de hoje
- Atribuir o nível Purdue de cada um
- Desenhar zonas e condutos, com a direção do tráfego observado
- Indicar se cada conduto tem algum controle real ou é um caminho aberto
- Apontar pelo menos um ponto concreto de segmentação frouxa ou ausente

# Entregável da aula

- Diagrama de zonas e condutos da bancada
- Captura Wireshark, com o pacote de escrita identificado
- Resposta: o que impediria, hoje, um notebook qualquer de fazer o mesmo que o cliente.js fez

# Fechamento

## O que ficou desta aula

O mesmo cliente.js da Aula 1 conversou com um CLP real, sem mudar uma linha, e o modelo Purdue nomeou o que já tinha ficado visível na prática: não existe fronteira entre o notebook e o CLP.

O diagrama de hoje é o ponto de partida para a modelagem de ameaça completa, na etapa de ataque controlado, sempre em bancada isolada.